

Lab 1 — Exploiting LLM APIs with excessive agency

Here you simply ask for the API exposed by the llm. You can see the sql api is exposed. Then you just create a SQL statement to delete the user.

Lab 2 — Exploiting vulnerabilities in LLM APIs

Here too you ask for the api exposed by the llm. You test with every exposed api and ask their argument. It was new to me that the apis that send email sometimes use remote code execution and sometimes use the OS command. So, I tried this and deleted the user.

Lab 3 — Indirect prompt injection

First, we check what APIs are exposed. After logging in, the delete API is exposed. Here we try attached the prompt in the reviews. The user frequently uses the live chat to ask about the product. We wait for the user to ask about the product. The llm couldn't figure out on the reviews command and execute it with the prompt given by the user. That way it deletes it.

The screenshot shows a web browser window with the URL <https://portswigger.net/web-security/all-labs#web-llm-attacks>. The page is titled "Web LLM attacks" and displays a list of five labs. A left sidebar contains a navigation menu with various security topics. The labs are as follows:

LAB	Difficulty	Lab Title	Status
LAB	APPRENTICE	Exploiting LLM APIs with excessive agency →	Solved
LAB	PRACTITIONER	Exploiting vulnerabilities in LLM APIs →	Solved
LAB	PRACTITIONER	Indirect prompt injection →	Solved
LAB	EXPERT	Exploiting insecure output handling in LLMs →	Solved
LAB	APPRENTICE	Exploiting AI agents to perform destructive actions →	Not solved

At the bottom of the page, there is a button labeled "Track your progress".

Lab 4 — Exploiting insecure output handling in LLMs

This handles LLM output insecurely leaving it vulnerable to XSS. We perform same step as the step 3 using indirect prompt injection and give XSS payload to execute.